Exercise 4

Ex. No.: 4

Detect Session Hijacking

Aim:

To understand and demonstrate session hijacking vulnerabilities using Cross-Site Scripting (XSS) in DVWA and to learn how to mitigate them by enabling the HttpOnly flag.

Procedure:

1. Setup

Install XAMPP (includes Apache + PHP + MySQL).

Download & install DVWA (Damn Vulnerable Web Application) into the htdocs folder.

Example path:

C:\xampp\htdocs\dvwa

Configure DVWA:

Start Apache + MySQL in XAMPP.

Open browser → http://localhost/dvwa.

Default login:

2. Enable XSS Attack in DVWA

Go to DVWA Security → set security to Low.

Navigate to XSS (Reflected) module.

In the input box, enter: <script>alert(document.cookie)</script>

Click submit PHPSESSID=abc123xyz

session hijacking via JavaScript is possible if HttpOnly is NOT enabled

3. Enable HttpOnly Flag

Open DVWA config file:

C:\xampp\htdocs\dvwa\config\config.inc.php

Add/modify PHP session setting (at the top or before session starts):

ini_set('session.cookie_httponly', 1);

Restart Apache server from XAMPP.

Test Again with HttpOnly

Go back to XSS (Reflected) module.

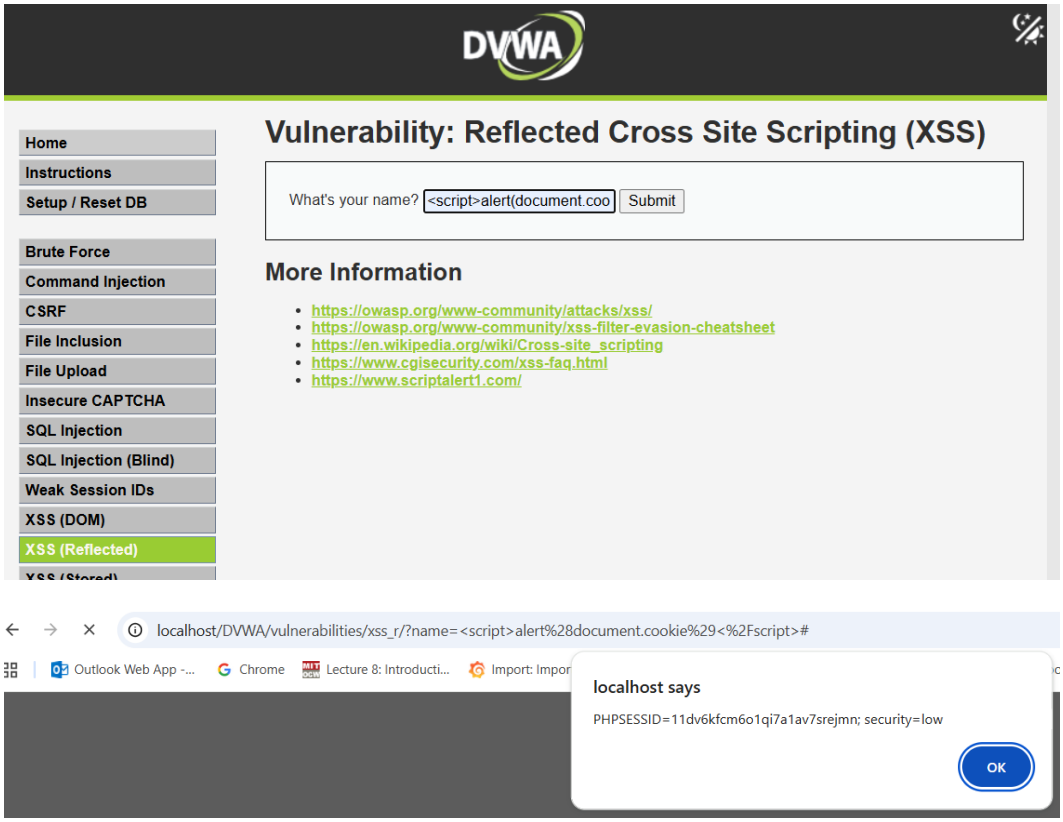
Inject the same payload:

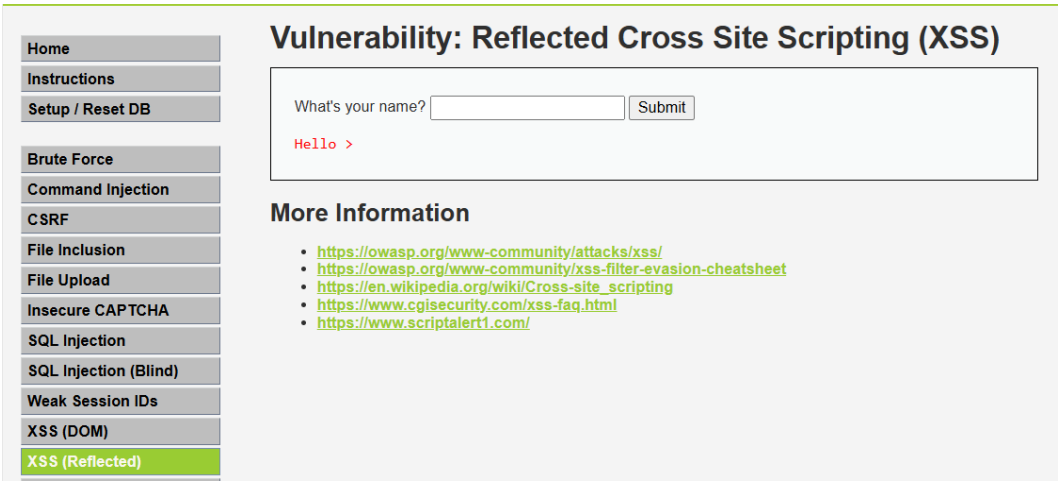
<script>alert(document.cookie)</script>

This time → the popup will show:

Result: Cross site scripting is prevented.

Screenshots




Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Submit
Hello >
More Information
https://owasp.org/www-community/attacks/xss/
https://owasp.org/www-community/xss-filter-evasion-cheatsheet
https://en.wikipedia.org/wiki/Cross-site_scripting
https://www.cgisecurity.com/xss-faq.html
https://www.scriptalert1.com/